

Production Security Configuration Policy

Policy ID: POL-SEC-002

Version: 1.0

Status: Approved for internal testing

Purpose

This policy defines internal infrastructure governance requirements for production systems. The controls are intentionally written in natural language so that a policy-to-evidence compliance application can extract them into structured, machine-evaluatable rules.

Policy Requirements

SEC-001 — Encryption at Rest

Production databases must have encryption at rest enabled.

SEC-002 — TLS Version

Production application endpoints must use TLS version 1.2 or higher.

SEC-003 — Public Database Access

Production database servers must not allow direct public network access.

SEC-004 — Backup Retention

Production databases must retain automated backups for at least 30 days.

Audit and Remediation

Control results should be reviewed after each compliance scan. Any failed control must be documented and remediated through the organization's established incident and change-management process.